Signature-DSS-Validation

Dokumentation & Benutzerhandbuch

Version 1.0

SIGN8 GmbH

November 2024

Inhaltsverzeichnis

1. Einleitung

2. Funktionsumfang

    2.1 Signatur-Validierung

    2.2 Registrierungs-Abgleich

    2.3 Detail-Analyse

3. Benutzung

    3.1 PDF validieren

    3.2 Registrierungsdaten abgleichen

4. Technische Architektur

    4.1 API-Anbindung

    4.2 EU DSS Format

    4.3 Technologie-Stack

5. Workflow: Registrierung & Validierung

6. Sicherheit & Datenschutz

7. Lizenzierung & Open Source

8. Glossar

1. Einleitung

Der **Signature-DSS-Validation** ist eine webbasierte Anwendung zur Validierung digitaler Signaturen und Siegel in PDF-Dokumenten. Die Anwendung nutzt die SIGN8 SVA (Signature Validation Authority) API, die auf dem EU Digital Signature Services (DSS) Framework basiert.

> **Zielgruppe:** Unternehmen, Behörden und Privatpersonen, die die Gültigkeit qualifizierter elektronischer Signaturen (QES) und qualifizierter elektronischer Siegel (QESeal) prüfen und mit Registrierungsdaten abgleichen möchten.

Kernfunktionen

- Validierung digitaler Signaturen und Siegel gemäß eIDAS-Verordnung
- Abgleich von Registrierungsdaten mit Zertifikatsinformationen
- Detaillierte Analyse von Zertifikatsketten und Vertrauensankern
- Unterstützung für QES (natürliche Personen) und QESeal (Organisationen)
- Vollständige EU DSS SimpleReport, DetailedReport und DiagnosticData Auswertung

2. Funktionsumfang

2.1 Signatur-Validierung

Der Validierungsmodus prüft alle digitalen Signaturen und Siegel eines PDF-Dokuments. Dabei werden folgende Aspekte geprüft:

PRÜFUNG	BESCHREIBUNG	DSS-FELD
Signaturstatus	Gültigkeit der kryptographischen Signatur	Indication
Zertifikatskette	Vertrauenskette bis zur Root-CA	CertificateChain
Zeitstempel	Qualifizierte Zeitstempel	Timestamps
Signaturformat	PAdES-Konformität	SignatureFormat
Signaturlevel	Qualifizierungsstufe (QES, QESeal, AdES)	SignatureLevel
Validierungsrichtlinie	Verwendete EU-Validierungspolicy	ValidationPolicy

DSS Indication-Werte

WERT	BEDEUTUNG	ANZEIGE
`TOTAL_PASSED`	Signatur vollständig gültig	Grün: Gültig
`INDETERMINATE`	Gültigkeit nicht abschließend prüfbar	Blau: Unbestimmt
`TOTAL_FAILED`	Signatur ungültig	Rot: Ungültig

2.2 Registrierungs-Abgleich

Der Registrierungs-Abgleich ermöglicht es, die Daten aus einer Registrierung (z.B. bei einer Zertifizierungsstelle) mit den tatsächlichen Zertifikatsinformationen auf dem signierten Dokument zu vergleichen.

Organisation (QESeal)

Für Organisationen werden folgende Felder aus dem Distinguished Name (DN) des Zertifikats geprüft:

EINGABEFELD	DN-FELD	OID
Organisationsname	O (Organization)	2.5.4.10
Land	C (Country)	2.5.4.6
Organisations-ID	organizationIdentifier / SerialNumber	2.5.4.97 / 2.5.4.5

Natürliche Person (QES)

Für natürliche Personen werden folgende Felder geprüft:

EINGABEFELD	DN-FELD	OID
Vorname	GivenName	2.5.4.42
Nachname	Surname	2.5.4.4
Land	C (Country)	2.5.4.6
Seriennummer	SerialNumber	2.5.4.5

2.3 Detail-Analyse (3-Level Drill-Down)

Die Ergebnisanzeige bietet drei Ebenen der Detailtiefe:

1. **Übersicht (Level 1):** Gesamtstatus, Anzahl gültiger/ungültiger Signaturen, Validierungsrichtlinie
2. **Signatur-Details (Level 2):** Pro Signatur: Status, Unterzeichner, Format, Level, Zeitpunkt, Signatur-ID
3. **Tiefe Details (Level 3):** Akkordeon-Bereiche für Validierungs-Details, Qualifizierungs-Details, Zertifikatskette, Signatur-Umfang, Zeitstempel, Erweiterte Zertifikats-Details

3. Benutzung

3.1 PDF validieren

1. Öffnen Sie die Anwendung im Browser
2. Stellen Sie sicher, dass der Tab **"Signatur-Validierung"** aktiv ist
3. Laden Sie ein PDF-Dokument hoch:
   - Per Drag & Drop in den Upload-Bereich ziehen, oder
   - Auf "Datei auswählen" klicken
4. Klicken Sie auf **"Jetzt validieren"**
5. Die Ergebnisse werden angezeigt:
   - Gesamtstatus (gültig/ungültig/unbestimmt)
   - Warnhinweis bei fehlender Zertifikatskette
   - Liste aller Signaturen und Zeitstempel
6. Klicken Sie auf eine Signatur, um Details zu sehen
7. Öffnen Sie die Akkordeon-Bereiche für tiefere Analyse

3.2 Registrierungsdaten abgleichen

1. Wechseln Sie zum Tab **"Registrierungs-Abgleich"**
2. Wählen Sie den Typ:
   - **Organisation (QESeal)** für Firmensignaturen/-siegel
   - **Natürliche Person (QES)** für persönliche Signaturen
3. Geben Sie die erwarteten Registrierungsdaten ein:
   - Pflichtfelder sind mit * markiert
   - Optionale Felder werden nur geprüft, wenn ausgefüllt
4. Laden Sie das signierte/gesiegelte PDF-Dokument hoch
5. Klicken Sie auf **"Jetzt validieren"**
6. Das Ergebnis zeigt:
   - **Abgleich erfolgreich** - alle geprüften Felder stimmen überein
   - **Teilweise übereinstimmend** - einige Felder stimmen nicht überein

- **Abgleich fehlgeschlagen** - keine Übereinstimmung

> **Hinweis:** Der Abgleich verwendet einen unscharfen Vergleich (Fuzzy Matching). Kleinere Abweichungen in der Schreibweise (z.B. Groß-/Kleinschreibung) werden toleriert. Der Abgleich ersetzt keine rechtliche Prüfung.

4. Technische Architektur

4.1 API-Anbindung

Die Anwendung kommuniziert mit der SIGN8 SVA API:

```
Endpunkt: POST https://api.uat.sign8.eu/sva/v1/validation/document/raw

Request Body:
{
    "document": "<Base64-kodiertes PDF>"
}

Response: DSS ValidationReport (JSON)
    - SimpleReport
    - DetailedReport
    - DiagnosticData
```

> Wird die Anwendung über den mitgelieferten Server (`npm start`) betrieben, leitet dieser die Anfragen serverseitig an die SVA API weiter. Bei rein statischem Hosting (z.B. GitHub Pages) ruft der Browser die SVA API direkt auf; dafür muss die API CORS für die jeweilige Domain erlauben.

4.2 EU DSS Format

Die API gibt Daten im standardisierten EU DSS Format zurück. Die wichtigsten Strukturen:

SimpleReport

Enthält die zusammengefassten Validierungsergebnisse mit dem Array `signatureOrTimestampOrEvidenceRecord` . Jedes Element ist in einem Wrapper-Objekt (`{Signature: {...}}` oder `{Timestamp: {...}}`) gekapselt.

DiagnosticData

Enthält detaillierte Zertifikatsinformationen unter `UsedCertificates` mit Subject Distinguished Name, Issuer, Gültigkeitszeitraum, Key Usage und weiteren Feldern.

4.3 Technologie-Stack

KOMPONENTE	TECHNOLOGIE
Frontend	Vanilla JavaScript (ES5+), HTML5, CSS3
Schriftart	Inter (Google Fonts)
API	SIGN8 SVA / EU DSS
Hosting	GitHub Pages
Build	Kein Build-Schritt erforderlich (statische Dateien)

5. Workflow: Registrierung & Validierung

Der typische Ablauf für die Überprüfung einer qualifiziert signierten/gesiegelten Registrierung:

Organisationen (QESeal)

1. **Registrierung:** Die Organisation registriert sich bei der zuständigen Stelle (z.B. Handelsregister, Aufsichtsbehörde) und erhält Registrierungsdaten (Firmenname, Registrierungsnummer, Land)
2. **Qualifiziertes Siegel:** Die Organisation lädt den Antrag/das Dokument herunter und versieht es mit einem qualifizierten elektronischen Siegel (QESeal) über einen qualifizierten Vertrauensdiensteanbieter (QTSP)
3. **Validierung & Abgleich:** Die empfangende Stelle nutzt den Signature-DSS-Validator:
   - Wechsel auf "Registrierungs-Abgleich"
   - Eingabe der Registrierungsdaten
   - Upload des gesiegelten PDF
   - Automatischer Abgleich der Zertifikats-Subject-Daten mit den Registrierungsdaten

Natürliche Personen (QES)

1. **Identifizierung:** Die natürliche Person identifiziert sich bei einem qualifizierten Vertrauensdiensteanbieter (z.B. per VideoIdent)
2. **Qualifizierte Signatur:** Die Person signiert das Dokument mit ihrer qualifizierten elektronischen Signatur (QES)
3. **Validierung & Abgleich:** Die empfangende Stelle prüft:
   - Wechsel auf "Registrierungs-Abgleich" → "Natürliche Person (QES)"
   - Eingabe von Vorname, Nachname (und ggf. Land, Seriennummer)
   - Upload des signierten PDF
   - Automatischer Abgleich mit den Zertifikats-Subject-Daten (GivenName, Surname, Country)

> **Wichtig:** Die Validierung prüft sowohl die kryptographische Gültigkeit der Signatur als auch die Übereinstimmung der Identitätsdaten. Beide Prüfungen müssen bestanden sein, um die Authentizität sicherzustellen.

6. Sicherheit & Datenschutz

Datenverarbeitung

- PDF-Dokumente werden ausschließlich zur Validierung an die SIGN8 SVA API übertragen
- Es werden keine Dokumente gespeichert (weder lokal noch serverseitig)
- Registrierungsdaten werden nur im Browser verarbeitet und nicht übertragen
- Der Abgleich erfolgt vollständig clientseitig im Browser

Empfehlungen für den Produktivbetrieb

- Betreiben Sie die Anwendung über den mitgelieferten Server oder erlauben Sie CORS auf der SVA API nur für die eigene Domain
- Implementieren Sie Rate-Limiting für API-Aufrufe
- Verwenden Sie HTTPS für alle Verbindungen
- Erwägen Sie eine Authentifizierung für den Zugriff auf die Anwendung

7. Lizenzierung & Open Source

Projektlizenz

Dieses Projekt steht unter der **MIT-Lizenz**. Es kann frei verwendet, modifiziert und verbreitet werden.

EU DSS Kompatibilität

Das EU Digital Signature Services (DSS) Framework wird unter der **LGPL-2.1**-Lizenz bereitgestellt. Da dieses Projekt:

- Keinen DSS-Quellcode enthält oder bündelt
- DSS ausschließlich über die SIGN8 SVA API als Service nutzt
- Nur die standardisierten JSON-Antwortformate verarbeitet

... bestehen **keine LGPL-Lizenzverpflichtungen** für dieses Projekt. Die LGPL-Pflichten treffen auf den Serverbetreiber zu, der DSS ausführt (in diesem Fall die SIGN8 SVA-Infrastruktur).

Verwendete Drittkomponenten

KOMPONENTE	LIZENZ	NUTZUNG
EU DSS	LGPL-2.1	Serverseitig via SIGN8 SVA API
Roboto, Plus Jakarta Sans	SIL OFL 1.1	Schriftarten (Google Fonts)

> Die vollständigen Lizenzhinweise finden Sie in den Dateien `LICENSE` und `THIRD-PARTY-NOTICES` im Projektverzeichnis.

8. Glossar

BEGRIFF	ERKLÄRUNG
DSS	Digital Signature Services - EU-Framework zur Signaturvalidierung
eIDAS	EU-Verordnung über elektronische Identifizierung und Vertrauensdienste
QES	Qualifizierte Elektronische Signatur - höchste Stufe der elektronischen Signatur, rechtlich gleichgestellt mit handschriftlicher Unterschrift
QESeal	Qualifiziertes Elektronisches Siegel - Siegel einer juristischen Person/Organisation
PAdES	PDF Advanced Electronic Signatures - Signaturformat für PDF-Dokumente
SVA	Signature Validation Authority - Dienst zur Signaturvalidierung
QTSP	Qualified Trust Service Provider - Qualifizierter Vertrauensdiensteanbieter
DN	Distinguished Name - Strukturierte Identifikation in X.509-Zertifikaten
CA	Certificate Authority - Zertifizierungsstelle
CORS	Cross-Origin Resource Sharing - Browser-Sicherheitsmechanismus

© 2024 SIGN8 GmbH · sign8.eu

Signature-DSS-Validation v1.0 · Open Source (MIT-Lizenz)

Validierung basiert auf EU Digital Signature Services (DSS) · LGPL-2.1